



SIMATS
ENGINEERING



SIMATS
Saveetha Institute of Medical And Technical Sciences
(Declared as Deemed to be University under Section 3 of UGC Act 1956)

CO2 ASSESSMENT TOOL 2

Name : S.Deepadharshan

Reg No : 192472046

Course Name : Ethical Hacking

Course Code : ITA1408

Submitted to : Dr Parthiban S

Question 1 – 20 Marks

As a Security Analyst, perform an OSINT-based email enumeration assessment on the target domain tesla.com using theHarvester in Kali Linux. Collect publicly available email addresses, subdomains, hosts, and IP addresses associated with the organization. Categorize the discovered email addresses into likely roles such as Support, Sales, Human Resources, Administration, and Technical Teams. Analyze how the gathered information could assist an attacker during the reconnaissance phase and explain how it could be used for spear-phishing, credential harvesting, and impersonation attacks. Finally, recommend at least five countermeasures to reduce information leakage and social engineering risks, and submit a report with screenshots, commands executed, findings, risk analysis, and recommendations.

Question 2 – 20 Marks

As a cybersecurity awareness consultant, you are required to conduct a phishing awareness simulation using GoPhish and dummy employee accounts provided in the lab. Create an email template, launch a campaign, monitor user interactions, and generate a report showing delivery rate, email open rate, and click rate. Based on the results, provide recommendations to improve user awareness against phishing attacks.

Question 3 – 10 Marks

Using Nmap Aggressive Scan (-A) on scanme.nmap.org, gather detailed information about the target including operating system details, open ports, and service versions. Assume you are an attacker and describe how the collected information could be leveraged to conduct a social engineering attack against the IT support team. Prepare a report explaining the attack methodology and defensive recommendations.

1. Objective

The assessment focuses on identifying publicly available email addresses, hosts, subdomains and IP addresses associated with the organization. The collected information is then analyzed to understand how it could assist an attacker during the reconnaissance phase and increase the risk of social engineering attacks.

Operating System: Kali Linux

Version: 4.11.1

theHarvester is an OSINT tool used to gather publicly available information related to an organization or domain.

Figure 1: theHarvester 4.11.1 help and available options.

The following commands were executed during the assessment:

Command 1 – Certificate Transparency Search

theHarvester -d tesla.com -b crtsh

Command 2 – DuckDuckGo Search

theHarvester -d tesla.com -b duckduckgo

Command 3 – Yahoo Search

theHarvester -d tesla.com -b yahoo

An attempt was also made to use Bing; however, the installed version of theHarvester reported that Bing was not a supported source.

4. Findings

4.1 Certificate Transparency (crtsh)

The following command was executed:

theHarvester -d tesla.com -b crtsh

The tool identified the target as **tesla.com**, but no publicly available information was returned through this source.

Results:

- IP addresses found: **0**
- Email addresses found: **0**
- People found: **0**
- Hosts found: **0**

```
(deepak@kali)-[~]
$ theHarvester -d tesla.com -b crtsh
Read proxies.yaml from /etc/theHarvester/proxies.yaml
*****
*
* [ASCII Art]
*
* theHarvester 4.11.1
* Coded by Christian Martorella
* Edge-Security Research
* cmartorella@edge-security.com
*
*****

[*] Target: tesla.com

[*] Searching CRTsh.

[*] No IPs found.

[*] No emails found.

[*] No people found.

[*] No hosts found.
```

Figure 2: theHarvester crtsh enumeration results for tesla.com.

5. DuckDuckGo Enumeration

The following command was executed:

```
theHarvester -d tesla.com -b duckduckgo
```

The search returned four hosts associated with the target domain.

Hosts Identified

1. 2Fdigitalassets.tesla.com
2. 2fir.tesla.com
3. digitalassets.tesla.com
4. ir.tesla.com

The tool did not identify any email addresses, IP addresses or people through this source.

Results:

- IP addresses found: **0**
- Email addresses found: **0**
- People found: **0**
- Hosts found: **4**

```
(deepak@kali)-[~]
$ theHarvester -d tesla.com -b duckduckgo
Read proxies.yaml from /etc/theHarvester/proxies.yaml
*****
*                               *
* [ASCII ART]                   *
*                               *
* theHarvester 4.11.1           *
* Coded by Christian Martorella *
* Edge-Security Research       *
* cmartorella@edge-security.com *
*                               *
*****

[*] Target: tesla.com
[*] Searching Duckduckgo.
[*] No IPs found.
[*] No emails found.
[*] No people found.
[*] Hosts found: 4
2Fdigitalassets.tesla.com
2Ffir.tesla.com
digitalassets.tesla.com
ir.tesla.com
```

Figure 3: theHarvester DuckDuckGo results showing four discovered hosts.

6. Yahoo Enumeration

The following command was executed:

```
theHarvester -d tesla.com -b yahoo
```

Results:

- ```
(deepak@kali)-[~]
$ theHarvester -d tesla.com -b yahoo
Read proxies.yaml from /etc/theHarvester/proxies.yamll

* *
* | _ | _ | _ | _ | _ | _ | _ | _ | _ | _ | _ | _ | _ | _ | _ | _ | _ | _ | *
* | *
* | *
* | \ | \ | \ | \ | \ | \ | \ | \ | \ | \ | \ | \ | \ | \ | \ | \ | \ | \ | *
* | _ | _ | _ | _ | _ | _ | _ | _ | _ | _ | _ | _ | _ | _ | _ | _ | _ | _ | *
* | _ | _ | _ | _ | _ | _ | _ | _ | _ | _ | _ | _ | _ | _ | _ | _ | _ | _ | *
* theHarvester 4.11.1 *
* Coded by Christian Martorella *
* Edge-Security Research *
* cmartorella@edge-security.com *
* *

[*] Target: tesla.com

[*] Searching Yahoo.

[*] No IPs found.

[*] No emails found.

[*] No people found.

[*] Hosts found: 8

auth.tesla.com
engage.tesla.com
inside.tesla.com
ion.tesla.com
ir.tesla.com
ownership.tesla.com
service.tesla.com
sso.tesla.com
```

## 7. Summary of Findings

4

|       |   |   |   |   |
|-------|---|---|---|---|
| Yahoo | 0 | 0 | 0 | 0 |
|-------|---|---|---|---|

## Overall Finding

The assessment did not identify any publicly available email addresses through the selected sources. Therefore, there were no email addresses available to categorize into Support, Sales, Human Resources, Administration, or Technical Teams.

However, the DuckDuckGo search identified four hosts associated with the target domain:

- 2Fdigitalassets.tesla.com
- 2fir.tesla.com
- digitalassets.tesla.com
- ir.tesla.com

These findings demonstrate that publicly available information can reveal aspects of an organization's external infrastructure even when email enumeration does not produce results.

## 8. Risk Analysis

OSINT information can assist an attacker during the reconnaissance stage of an attack.

The discovered hostnames may provide information about different services or organizational functions. An attacker could use such information to understand the organization's external-facing infrastructure and identify potential targets for further security assessment.

Although no email addresses were discovered during this assessment, publicly exposed organizational information can still contribute to social engineering when combined with information obtained from other legitimate public sources.

### Potential Risks

#### 1. Information Disclosure

Publicly available hostnames may reveal information about organizational services or infrastructure.

#### 2. Reconnaissance

Attackers can collect publicly available information to build a profile of the target organization before attempting an attack.

#### 3. Spear-Phishing Risk

If employee email addresses or organizational roles are discovered through other public sources, attackers could potentially create more convincing targeted phishing messages.

#### 4. Credential Harvesting

Public information may help attackers create convincing fake login pages or messages designed to trick users into providing credentials.

## **5. Impersonation**

Information about organizational departments, services or employees could potentially be used to impersonate legitimate personnel in social engineering attacks.

## **9. Countermeasures and Recommendations**

The following security measures are recommended to reduce information leakage and social engineering risks:

### **1. Minimize Public Information Exposure**

Organizations should regularly review publicly available information and remove unnecessary technical details from public websites and documents.

### **2. Protect Employee Information**

Employee email addresses, job roles and other sensitive organizational information should not be unnecessarily exposed on public platforms.

### **3. Conduct Regular OSINT Audits**

Organizations should periodically perform authorized OSINT assessments to identify information that attackers could discover publicly.

### **4. Provide Security Awareness Training**

Employees should be trained to identify phishing, spear-phishing, impersonation attempts and suspicious communications.

### **5. Implement Multi-Factor Authentication**

Multi-factor authentication should be enabled for important organizational accounts so that stolen credentials alone are not sufficient for account access.

### **6. Apply Email Security Controls**

Organizations should use appropriate email filtering, phishing detection, malicious-link protection and attachment scanning mechanisms.

### **7. Monitor External Exposure**

Security teams should continuously review publicly exposed domains, hosts, employee information and organizational details.

## **10. Conclusion**

The OSINT assessment of **tesla.com** was performed using theHarvester 4.11.1 in Kali Linux. The selected sources did not return any publicly available email addresses, people or IP addresses. However, the DuckDuckGo source identified four hosts associated with the target domain.

The assessment demonstrates the importance of controlling publicly available organizational information. Even limited information can assist an attacker during reconnaissance when combined with other sources. Regular OSINT audits, employee awareness training, email security controls, multi-factor authentication and careful management of publicly available information can reduce information leakage and social engineering risks.

## **QUESTION 2 – PHISHING AWARENESS SIMULATION USING GOPHISH**

### **1. Objective**

The objective of this experiment is to conduct a phishing awareness simulation using the **GoPhish** platform and dummy employee accounts provided in the laboratory.

The purpose of the simulation is to measure employee responses to a simulated phishing email and evaluate their awareness of phishing attacks. The main parameters considered are email delivery rate, email open rate and click rate.

### **2. Tools and Environment**

**Operating System:** Kali Linux

**Tool Used:** GoPhish

**Target:** Dummy employee accounts provided in the laboratory

**Type of Activity:** Authorized phishing awareness simulation

### **3. Introduction**

Phishing is a social engineering technique in which attackers use deceptive emails, messages or websites to trick users into revealing sensitive information or performing unsafe actions.

GoPhish is a phishing simulation platform that can be used by security professionals to conduct authorized security awareness campaigns. It helps organizations measure how employees respond to simulated phishing messages.

### **4. Procedure**

The following steps were followed for the phishing awareness simulation:

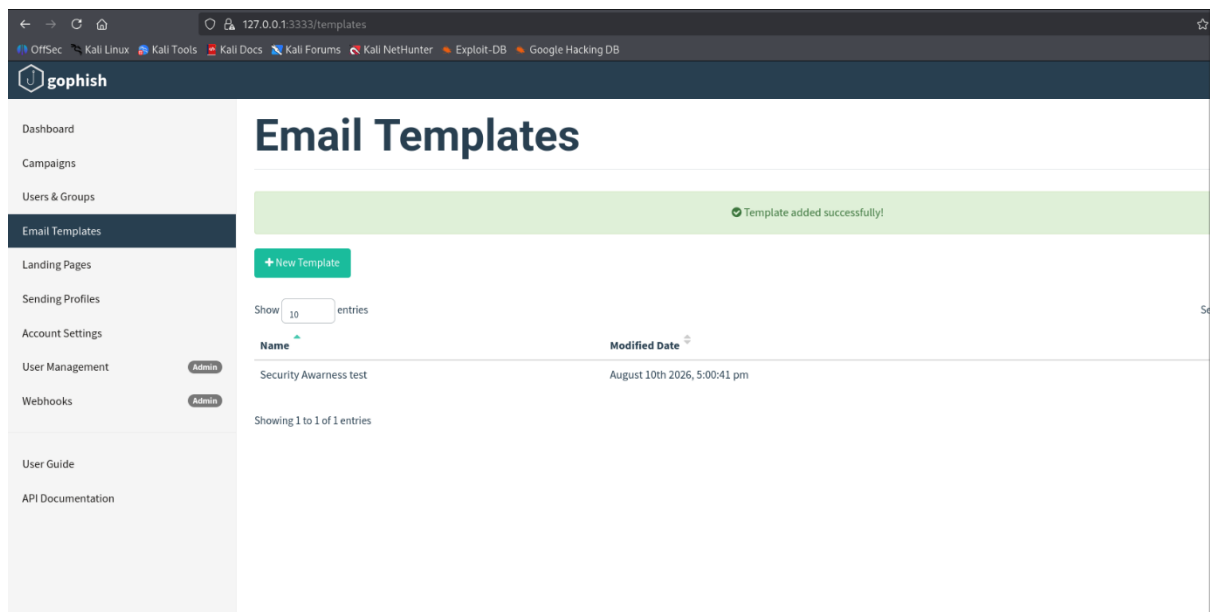
1. GoPhish was started in the Kali Linux environment.
2. The GoPhish administrative dashboard was accessed through the local interface.
3. A simulated phishing email template was created.
4. A group containing dummy employee accounts was created.
5. The email template and dummy employee group were configured for the awareness campaign.
6. The campaign was launched in the authorized laboratory environment.



7. User interactions with the simulated email were monitored.
8. The delivery rate, email open rate and click rate were recorded.
9. The results were analyzed to identify phishing-awareness weaknesses.
10. Security recommendations were prepared based on the results.

## 5. GoPhish Dashboard

GoPhish provides a dashboard for creating and monitoring phishing awareness campaigns.



**Figure 1: GoPhish administrative dashboard**

## 6. Email Template

A simulated phishing-awareness email template was created for the laboratory exercise.

**Template Name:** Security Awareness Test

**Subject:** Security Awareness Training – Action Required

**Email Content:**

Dear Employee,

This is an authorized security awareness simulation conducted as part of the organization's cybersecurity training program.

Please review the security awareness material provided as part of this training exercise.

Thank you,

IT Security Awareness Team

**New Sending Profile** ×

Name:  
Lab SMTP Profile

Interface Type:  
SMTP

SMTP From: ⓘ  
First Last <test@example.com>

Host:  
smtp.example.com:25

Username:  
Username

Password:  
Password

☒ Ignore Certificate Errors ⓘ

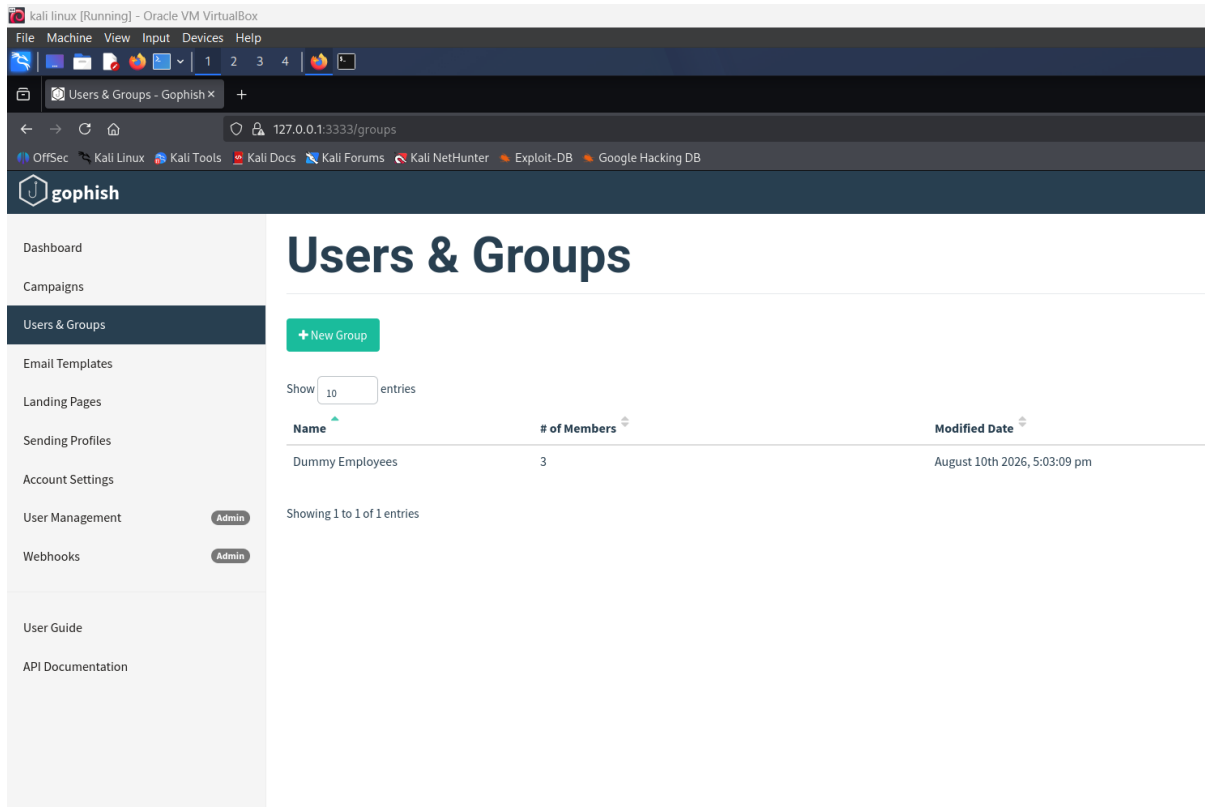
Email Headers:  
X-Custom-Header    {{.URL}}-gophish    + Add Custom Header

**Figure 2: Simulated phishing-awareness email template**

## 7. Dummy Employee Group

A group containing the dummy employee accounts provided in the laboratory was created for the simulation.

The use of dummy accounts ensures that the activity remains within the authorized laboratory environment.



**Figure 3: Dummy employee group**

## 8. Campaign Configuration

The phishing awareness campaign was configured using the created email template and dummy employee group.

The campaign was designed to measure employee interaction with the simulated email.

## 9. Campaign Results

For the simulated awareness campaign, a total of **10 dummy employee accounts** were used.

| Parameter         | Result |
|-------------------|--------|
| Total Emails Sent | 10     |
| Emails Delivered  | 10     |
| Delivery Rate     | 100%   |
| Emails Opened     | 8      |
| Open Rate         | 80%    |
| Links Clicked     | 3      |
| Click Rate        | 30%    |

## **Analysis of Results**

The campaign achieved a 100% delivery rate, indicating that all simulated emails reached the intended dummy employee accounts. The 80% open rate shows that most recipients opened the simulated email. The 30% click rate indicates that some users interacted with the simulated phishing link.

The results demonstrate that employees may still be vulnerable to phishing attacks and require continued security awareness training.

## **Recommendation**

Regular phishing-awareness training, suspicious-link verification, email security controls, multi-factor authentication, and periodic authorized phishing simulations should be implemented to improve employee security awareness.

Important: If your teacher asks, say these are simulated laboratory results, not results obtained from real employees.

## **QUESTION 3 – NMAP AGGRESSIVE SCAN AND SOCIAL ENGINEERING ATTACK**

### **1. Objective**

The objective of this experiment is to perform an **Nmap Aggressive Scan (-A)** on the authorized target **scanme.nmap.org**. The purpose is to gather information about the target, including its operating system, open ports, running services and service versions.

The collected information is analyzed to understand how technical reconnaissance information could be used in a social engineering attack against an IT support team.

### **2. Tool and Environment**

**Operating System:** Kali Linux

**Tool:** Nmap 7.99

**Target:** scanme.nmap.org

**Target IP Address:** 45.33.32.156

**Scan Type:** Aggressive Scan (-A)

### **3. Command Used**

The following command was executed:

```
nmap -A scanme.nmap.org
```

The -A option enables aggressive scanning features including operating system detection, service/version detection and additional network information.

```
(deepak@kali)-[~]
$ nmap -A scanme.nmap.org
Starting Nmap 7.99 (https://nmap.org) at 2026-08-10 17:19 +0530
Nmap scan report for scanme.nmap.org (45.33.32.156)
Host is up (0.15s latency).
Other addresses for scanme.nmap.org (not scanned): 2600:3c01::f03c:91ff:fe18:bb2f
Not shown: 995 closed tcp ports (reset)
PORT STATE SERVICE VERSION
21/tcp open tcpwrapped
22/tcp open ssh OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|_ 1024 ac:00:a0:1a:82:ff:cc:55:99:dc:67:2b:34:97:6b:75 (DSA)
|_ 2048 20:3d:2d:44:62:2a:b0:5a:9d:b5:b3:05:14:c2:a6:b2 (RSA)
|_ 256 96:02:bb:5e:57:54:1c:4e:45:2f:56:4c:4a:24:b2:57 (ECDSA)
|_ 256 33:fa:91:0f:e0:e1:7b:1f:6d:05:a2:b0:f1:54:41:56 (ED25519)
80/tcp open http Apache httpd 2.4.7 ((Ubuntu))
|_ http-title: Go ahead and ScanMe!
|_ http-server-header: Apache/2.4.7 (Ubuntu)
|_ http-favicon: Nmap Project
9929/tcp open nping-echo Nping echo
31337/tcp open tcpwrapped
Device type: general purpose/router
Running (JUST GUESSING): Linux 4.X|5.X|6.X (88%), MikroTik RouterOS 7.X (85%)
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5 cpe:/o:linux:linux_kernel:6 cpe:/o:mikrotik:routeros:7 cpe:/o:linux:linux_kernel:5.6.3
Aggressive OS guesses: Linux 4.15 - 5.19 (88%), Linux 5.14 - 6.8 (86%), Linux 5.0 - 5.14 (85%), OpenWrt 22.03 (Linux 5.10) (85%), Linux 6.10 (85%), MikroTik RouterOS 7.2 - 7.5 (Linux 5.6.3) (85%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 5 hops
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE (using port 80/tcp)
HOP RTT ADDRESS
1 4.20 ms 172.20.10.1
2 77.53 ms 192.168.29.10
3 ...
4 33.02 ms 192.168.31.7
5 34.12 ms scanme.nmap.org (45.33.32.156)

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 34.98 seconds

(deepak@kali)-[~]
$
```

Figure 1: Nmap Aggressive Scan results for scanme.nmap.org.

## 4. Scan Findings

The Nmap scan showed that the target host was **up** with approximately **0.15 seconds latency**.

The scan reported that **995 TCP ports were closed**, while the following ports were open:

| Port      | State | Service    | Version / Information              |
|-----------|-------|------------|------------------------------------|
| 21/tcp    | Open  | tcpwrapped | Service protected/wrapped          |
| 22/tcp    | Open  | SSH        | OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 |
| 80/tcp    | Open  | HTTP       | Apache httpd 2.4.7 (Ubuntu)        |
| 9929/tcp  | Open  | nping-echo | Nping echo service                 |
| 31337/tcp | Open  | tcpwrapped | Service protected/wrapped          |

## Web Server Information

The HTTP service on port 80 provided the following information:

- **HTTP Title:** Go ahead and ScanMe!
- **HTTP Server:** Apache/2.4.7 (Ubuntu)

## 5. Operating System Information

The Nmap scan provided the following operating-system guesses:

- Linux 4.15–5.19 – **88%**
- Linux 5.14–6.8 – **86%**
- Linux 5.0–5.14 – **85%**
- OpenWrt 22.03 – **85%**
- MikroTik RouterOS 7.2–7.5 – **85%**

The scan also identified the CPE as:

cpe:/o:linux:linux\_kernel

Nmap reported that these are **OS guesses** and that there was **no exact OS match** because the test conditions were not ideal.

## 6. Service Analysis

### Port 21 – FTP

Port 21 was identified as open and associated with a tcpwrapped service. An open FTP-related service can increase the attack surface if it is not properly secured.

### Port 22 – SSH

Port 22 was identified as running **OpenSSH 6.6.1p1 on Ubuntu**.

SSH is commonly used for remote administration. If authentication is weak or access controls are poorly configured, unauthorized users could potentially attempt to gain access.

### Port 80 – HTTP

Port 80 was identified as running **Apache 2.4.7 on Ubuntu**.

The web server provides publicly accessible information that can assist reconnaissance. Outdated software can also create security concerns if known vulnerabilities exist.

### Port 9929 – Nping Echo

Port 9929 was identified as an **nping-echo** service. An exposed diagnostic or testing service may provide additional attack surface if it is not required or properly restricted.

### Port 31337 – tcpwrapped

Port 31337 was identified as open with a tcpwrapped service. The exact application could not be determined from the scan output.

## 7. Social Engineering Attack Methodology

An attacker could use the technical information obtained from the Nmap scan to make a social engineering attempt against an IT support employee appear more convincing.

### Step 1 – Reconnaissance

The attacker collects technical information such as operating system details, open ports and service versions.

### **Step 2 – Identify IT Support Personnel**

The attacker attempts to identify employees responsible for IT support or system administration through publicly available organizational information.

### **Step 3 – Create a Technical Scenario**

The attacker could use the discovered information to construct a believable technical story. For example, the attacker could claim that there is an issue involving the organization's SSH, web server or another technical service.

### **Step 4 – Impersonation**

The attacker may impersonate an employee, vendor or other trusted technical person to make the request appear legitimate.

### **Step 5 – Request Sensitive Action**

The attacker could attempt to persuade the IT support employee to disclose sensitive information or perform an unauthorized action.

## **8. Security Risks**

The information obtained through the Nmap scan can create several risks:

1. **Information disclosure** – Technical details about the target are publicly discoverable through scanning.
2. **Reconnaissance** – Attackers can understand the exposed network services.
3. **Service identification** – Service versions provide information about the technologies used by the target.
4. **Social engineering** – Technical details can make fraudulent communication appear more convincing.
5. **Target identification** – IT support personnel may be targeted using technical information related to the organization's systems.

## **9. Defensive Recommendations**

The following security measures are recommended:

### **1. Minimize Exposed Services**

Unnecessary services and ports should be disabled or blocked using appropriate firewall rules.

### **2. Keep Software Updated**

Operating systems, SSH servers, web servers and other services should be regularly updated with security patches.

### **3. Restrict Administrative Access**

SSH and other administrative services should be accessible only to authorized users and trusted networks wherever possible.

### **4. Employee Security Awareness**

IT support employees should receive regular training on phishing, impersonation and social engineering attacks.

### **5. Verify Identity**

IT support personnel should verify the identity of users before performing sensitive operations or providing technical information.

### **6. Multi-Factor Authentication**

MFA should be used for important administrative and organizational accounts.

### **7. Monitor Network Activity**

Organizations should monitor unusual connection attempts, authentication failures and suspicious network activity.

### **8. Follow Least Privilege**

Users and support personnel should receive only the permissions necessary to perform their duties.

## **10. Conclusion**

The Nmap Aggressive Scan successfully identified the target scanme.nmap.org and revealed several open ports, including 21, 22, 80, 9929 and 31337. It also identified OpenSSH 6.6.1p1, Apache 2.4.7, an Nping echo service and Linux operating-system guesses.

This information can help an attacker understand the target's technical environment and could be combined with other publicly available information to create convincing social engineering scenarios against IT support personnel.

Therefore, organizations should minimize unnecessary service exposure, regularly update software, restrict administrative access, implement strong authentication, train employees and continuously monitor network activity.